



CertiFlow: Admin CRUD & RBAC Strategy

This document defines the administrative operations, hierarchical permissions, and bulk data management for the CertiFlow platform.



1. Role-Based Access Control (RBAC) Matrix

We implement a strict hierarchy to ensure security across administrative tiers.

Feature	Super Admin	General Admin	Employee
Manage Gen-Admin Accounts	✓ CRUD	✗ No Access	✗ No Access
Manage Employee Accounts	✓ CRUD	✓ CRUD	✗ No Access
Reset Gen-Admin Password	✓ Yes	✗ No	✗ No
Reset Employee Password	✓ Yes	✓ Yes	✗ No (Self-service only)
Bulk Upsert Employees	✓ Yes	✓ Yes	✗ No



2. Hierarchical Password Reset Logic

The **Gatekeeper Agent** must implement the following logic in the POST `/users/:id/reset-password` endpoint:

1. **Identity Verification:** Extract `requestor_role` and `requestor_id` from the JWT.
2. **Target Verification:** Query the database for the `target_user_role`.
3. **Hierarchy Check:**
 - If `requestor_role == 'SUPER_ADMIN'`: Authorized to reset anyone.
 - If `requestor_role == 'GEN_ADMIN'`: Authorized ONLY if `target_user_role == 'EMP'`.
 - Otherwise: Return **403 Forbidden**.
4. **Action:** Generate a new hash (default: last 6 digits of `thai_id`) and update `password_hash`.
5. **Invalidate Sessions:** Clear any active refresh tokens for the target user to force

re-authentication.

3. Bulk Sync (Upsert) Implementation

To handle large-scale updates (e.g., Marriott monthly staff updates), we use the **"Upsert" (Update or Insert)** pattern based on the emp_id.

The Logic (Node.js/PostgreSQL):

The **Data Engineer Agent** will implement a POST /employees/bulk endpoint that accepts an array of employee objects.

- **Step 1: Validation:** Use Zod to validate the array schema (ensure emp_id and thai_id exist).
- **Step 2: Database Transaction:** Use the INSERT ... ON CONFLICT SQL syntax for performance.
- **Step 3: Unique Key:** Use emp_id as the conflict target.

SQL Example:

```
INSERT INTO employees (emp_id, first_name, last_name, thai_id, position, department,
base_salary, is_active)
VALUES ($1, $2, $3, $4, $5, $6, $7, $8)
ON CONFLICT (emp_id)
DO UPDATE SET
  first_name = EXCLUDED.first_name,
  last_name = EXCLUDED.last_name,
  position = EXCLUDED.position,
  department = EXCLUDED.department,
  base_salary = EXCLUDED.base_salary,
  is_active = EXCLUDED.is_active,
  updated_at = CURRENT_TIMESTAMP;
```

4. Updated Agent Tasks

The Gatekeeper Agent (Backend)

- **API Security:** Guard all CRUD routes with a checkRole(['SUPER_ADMIN', 'GEN_ADMIN']) middleware.
- **Hierarchy Enforcement:** Write the logic to prevent General Admins from modifying Super Admin records.

The Interface Agent (Frontend)

- **Admin Management UI:** A dedicated panel to list users with filtering by role.
- **Bulk Upload UI:** A drag-and-drop zone for CSV files that sends data to the Bulk API.

The Craftsman Agent (Worker)

- **Audit Logging:** Every password reset or bulk change must be logged in a `system_audit_logs` table (who did what, to whom, and when).